秘密鍵と署名判断をTEEに隔離した Web3トランザクションの安全な自動署名

濱口 健人[1,a)]　瀧田 愼[1]　野村 健太[2]　林田 淳一郎[2]　石井 龍[2]　佐古 健太郎[2]　永井 達也[2]
渡邉 卓弥[2]　齋藤 恆和[2]　高田 雄太[2]　熊谷 裕志[2]　神薗 雅紀[2,3]　葛野 弘樹[1]　白石 善明[1,b)]

概要：Web3 における定期送金や条件付き決済では，トランザクション署名の自動化が有用である．しかし，クライアント PC が侵害されると，秘密鍵を専用装置へ隔離しても，装置は改ざんされたトランザクションへの署名を要求される可能性がある．本稿では，クライアント PC，通信経路，および署名装置の通常実行領域を信頼せず，秘密鍵，ポリシー照合，署名判断，署名生成を TEE 内に隔離する Web3 トランザクションの自動署名システムを提案する．利用者は自動署名を許す範囲をポリシーとして事前承認し，システムはポリシーに適合する要求を自動署名する．照合可能だがポリシー外の要求はユーザー確認へ移し，照合不能な要求は拒否する．Raspberry Pi 3B+と OP-TEE による実装では，TEE 内で生成した署名済みトランザクションが Ethereum 互換の実験チェーンで受理され，ポリシーを満たす要求を平均 670 ms で処理した．

キーワード：Trusted Execution Environment，TrustZone，Web3 ウォレット，トランザクション署名，ポリシー制御

Secure Automatic Signing of Web3 Transactions with the Private Key and Signing Decision Isolated in a TEE

Kento Hamaguchi[1,a)]　Makoto Takita[1]　Kenta Nomura[2]　Junichiro Hayata[2]　Ryu Ishii[2]
Kentaro Sako[2]　Tatsuya Nagai[2]　Takuya Watanabe[2]　Tsunekazu Saito[2]　Yuta Takata[2]
Hiroshi Kumagai[2]　Masaki Kamizono[2,3]　Hiroki Kuzuno[1]　Yoshiaki Shiraishi[1,b)]

Abstract: Automatic transaction signing is useful for recurring transfers and conditional payments in Web3. However, if the client PC is compromised, even when the private key is isolated in a dedicated device, the device may be requested to sign a tampered transaction. In this paper, we propose an automatic signing system for Web3 transactions that assumes the client PC, communication path, and normal execution environment of the signing device to be untrusted, and isolates the private key, policy matching, signing decision, and signature generation within a Trusted Execution Environment (TEE). The user pre-approves a policy that defines the scope of transactions permitted for automatic signing, and the system automatically signs requests that comply with the policy. Requests that can be matched against the policy but fall outside it are forwarded for user confirmation, whereas requests that cannot be matched are rejected. In our implementation using a Raspberry Pi 3B+ and OP-TEE, transactions signed within the TEE were successfully accepted by an Ethereum-compatible experimental blockchain, and requests satisfying the policy were processed in 670 ms on average.

Keywords: trusted execution environment, TrustZone, Web3 wallet, transaction signing, policy enforcement

[1] 神戸大学
Kobe University
[2] デロイト トーマツ サイバー合同会社
Deloitte Tohmatsu Cyber LLC
[3] 一般社団法人デロイト トーマツ戦略研究所
Deloitte Tohmatsu Strategy Institute
[a)] hamaguchi.kento@gsuite.kobe-u.ac.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

Ethereum をはじめとする Web3 では，送金やスマートコントラクト呼び出しを実行する際，秘密鍵を用いてトランザクションに署名する．署名はアカウント所有者によるトランザクション実行の承認とみなされるため，秘密鍵の管理に加え，署名対象が利用者の意図と一致することが重要である．定期送金や条件付き決済のようにトランザクション要求が継続的に発生する用途では，要求ごとの署名操作が継続運用の負担となる．

クライアント PC は，トランザクションの生成とブロックチェーンへの送信を担う一方，マルウェア感染などによって侵害される可能性がある．暗号資産ウォレットに関する既存研究では，秘密鍵の窃取に加え，トランザクションの生成・表示・署名の各段階が攻撃対象となることが報告されている [1], [2]．したがって，クライアント PC 上に秘密鍵と署名機能を置いて自動実行する構成では，PC の侵害により，秘密鍵の漏洩や意図しないトランザクションへの署名が生じうる．

秘密鍵をハードウェアウォレット等の専用装置に隔離することで，クライアント PC から秘密鍵を直接読み出されるリスクを低減できる．しかし，PC を侵害した攻撃者は，送金先や送金額を改ざんした署名要求を専用装置へ送信できる．ハードウェアウォレットの安全性は，署名対象を正しく確認できることにも依存する [3]．また，ホスト上のアドレスを書き換える EthClipper 攻撃が報告されている [4]．このため，鍵の隔離に加え，署名装置がトランザクションから署名判断に必要なデータを抽出し，クライアント PC から独立して署名可否を判断する必要がある．

利用者が署名要求を確認すれば，その内容が意図に沿うかを判断できる．しかし，すべての要求に確認を求める方式では，署名の完了に利用者の操作が必要となるため，トランザクションの実行を完全には自動化できない．そこで，利用者は，自動署名を許可する範囲を機械的に判定可能な条件として事前に設定する．本稿では，この条件を「ポリシー」と呼び，自動署名の事前承認基準として用いる．署名装置は，トランザクションから署名対象データを抽出し，そのうちポリシーの対象となる項目を登録済みポリシーと照合する．署名対象データを安全に抽出できない要求は拒否する．抽出できた要求は，ポリシーに適合する場合に自動署名し，適合しない場合にユーザー確認へ移す．

本稿では，クライアント PC，クライアント PC と署名装置間の通信路，および署名装置の Normal World を信頼しないことを前提とする．その上で，秘密鍵，署名対象データの抽出，ポリシー照合，署名判断，署名生成を Trusted Execution Environment（TEE）内に隔離する自動署名システムを提案する．本稿の貢献は次の 3 点である．

（1） 秘密鍵を TEE 内に隔離し，署名対象データの抽出，ポリシー照合，署名判断を TEE 内で実行することで，クライアント PC からの要求を未信頼入力として扱う構成を提案する．

（2） 署名対象データを安全に抽出できない要求には署名しないという設計原理に基づき，抽出の可否とポリシーへの適合結果に応じて，署名要求の処理を自動署名，ユーザー確認，拒否の三つに分岐する方式を提案する．

（3） Raspberry Pi 3B+と OP-TEE を用いて提案システムを実装し，Ethereum 互換の実験チェーンにおける署名済みトランザクションの受理，署名判断の各分岐，および処理時間を確認する．

評価対象は Raspberry Pi 3B+と OP-TEE による実装および Ethereum 互換の実験チェーンとする．

2. 関連研究と本稿の位置付け

2.1 鍵と署名処理の隔離

TEE は，通常の OS が動作する領域から分離された実行環境を提供する．Pinto と Santos は，Arm TrustZone を用いた TEE システムを体系的に調査し，機密データとセキュリティ上重要な処理を Normal World から分離する構成を整理している [5]．1 章で述べたハードウェアウォレットは，秘密鍵と署名処理を専用装置に隔離する一方，署名対象の確認を利用者に委ねる [3]．

TrustZone を暗号資産ウォレットに適用した例として，Gentilal らは TrustZone-backed Bitcoin Wallet[6] を，Dai らは軽量 Bitcoin ウォレット SBLWT[7] を提案している．これらは鍵管理や署名処理を未信頼なホストから隔離する．一方，本稿が扱う課題は，隔離された鍵で署名してよいトランザクションを，署名装置がどのように選別するかである．

2.2 ユーザー承認の保護

Athalye らの Notary では，隔離された Bitcoin 承認エージェントが秘密鍵を保持し，トランザクションを解析して専用画面に表示する．利用者が物理ボタンで承認した場合にのみ署名されるため，署名可否の最終判断は利用者に委ねられる [8]．また，小林と面は，秘密鍵と署名処理を TrustZone 内に隔離し，利用者が Trusted UI を通じてトランザクションの内容を確認するコールドウォレットを提案している [9]．SecurePay は，侵害されたホスト上での取引内容表示の完全性を扱う [10]．これらの方式は，人が署名対象を確認する経路の保護に重点を置く．しかし，いずれも要求ごとにユーザー承認を必要とする点で，ポリシーに適合する要求を利用者の操作なしに処理する本稿の自動署名とは目的が異なる．

b) zenmei@port.kobe-u.ac.jp

© 2026 Information Processing Society of Japan

2.3 意味提示と自動実行

ERC-7730 は，スマートコントラクトの calldata を人が理解しやすい形式で提示する Clear Signing の標準化を提案している [11]．ERC-4337 は，アカウント抽象化により，ユーザー操作の検証条件をオンチェーンで柔軟に記述する仕組みを提案している [12]．しかし，オンチェーン検証は署名済みの操作が条件を満たすかを検証するものであり，署名鍵そのものの侵害を防ぐものではない．署名鍵が未信頼なクライアント PC 上に置かれている場合，攻撃者はポリシーの範囲内で署名鍵を任意に使用できるだけでなく，ポリシー変更やセッションキー更新のトランザクションにも署名しうる．ERC-7730 と ERC-4337 は，それぞれ意味提示とオンチェーン検証を拡張する提案であり，独立した署名装置が未署名トランザクションを選別する問題を主な対象としない．

Pan らの OmniIntent は，トリガ条件，トランザクション操作，実行時制約からなる ICL で記述された意図を TEE 内で解析し，トランザクションの生成と署名を TEE 内で行う．この方式は，事前承認に基づき，条件成立後に利用者の追加操作なしで処理を実行する [13]．OmniIntent が利用者の意図からトランザクションを構成するのに対し，本稿では，未信頼クライアントが生成した未署名トランザクションを独立した署名装置で検査し，事前承認された範囲に限って自動署名する手法を提案する．

2.4 本稿の位置付け

表 1 では，本稿の課題に関係する代表的な方式を，秘密鍵の隔離，隔離環境内での自動的な署名判断，事前条件に基づく自動署名，ユーザー確認経路の保護，および未信頼クライアントが生成した署名要求の自動判定という 5 軸で整理する．ここで「隔離内判定」は，人手で要求ごとに確認するのではなく，隔離環境内のプログラムがトランザクションの内容に基づいて署名判断を行うことを指す．「確認経路の保護」は，ユーザー確認に用いる表示経路が未信頼領域から保護されていることを指す．また「未信頼 Tx 判定」は，未信頼クライアントが生成した未署名トランザクションを隔離環境内で検査し，署名可否を自動的に判定することを指す．表中の ✓ は，引用文献において当該項目への対応が確認できたことを示す．—は，当該方式がその項目を主な対象としていないことを示す．ただし，本表は引用文献の記載に基づく機能比較であり，各方式の全機能を網羅するものではない．

本稿では，鍵の隔離と隔離環境内での自動処理を前提として，未信頼クライアントが生成した未署名トランザクションから TEE 内で署名対象データを抽出する．さらに，抽出したデータのうちポリシーの対象となる項目を，利用者が事前承認したポリシーと照合し，署名可否を判断する．この判定では，ポリシーに適合する要求に自動的に署名し，ポリシーの範囲外にある要求にはユーザー確認を求める．一方，署名対象データを安全に抽出できない要求は拒否する．なお，本実装では，ユーザー確認の表示・入力に Normal World を使用しており，Trusted UI の実装は今後の課題である．

表 1: 関連方式との機能比較
Table 1 Functional comparison with related approaches.

方式	鍵隔離	隔離内判定	事前条件自動署名	確認経路の保護	未信頼 Tx 自動判定
HW 型 [3]	✓	—	—	—	—
TrustZone 型 [6], [7]	✓	—	—	—	—
Notary[8]	✓	—	—	✓	—
TUI 型 [9]	✓	—	—	✓	—
OmniIntent[13]	✓	✓	✓	—	—
提案手法	✓	✓	✓	(設計のみ)	✓

3. 脅威モデルとセキュリティ要件

3.1 信頼境界と攻撃者

提案システムは，Web3 トランザクションを生成・送信するクライアント PC，クライアント PC と署名装置の間の通信路，および署名装置の Normal World を信頼しない．攻撃者はこれらを侵害し，署名要求やポリシーの登録・変更要求を改ざん，差し替え，または欠落させられるものとする．具体的には，攻撃者が送金先，送金額，chainId，gas，呼び出し先コントラクト，関数セレクタ，および引数を利用者の意図と異なる値に変更し，署名装置から有効な署名を得ようとする攻撃を想定する．

一方，TEE 内で動作する Trusted Application（TA）と，TEE を Normal World から分離する OP-TEE の隔離機構を信頼する．隔離実行環境そのものの脆弱性，ブートチェーンの侵害，物理攻撃，サイドチャネル攻撃，暗号プリミティブの安全性の破綻，RPC ノードやブロックチェーン基盤への攻撃，およびサービス妨害を脅威の対象外とする．また，ユーザー確認に用いる表示・入力は Normal World を介するため，本稿ではその完全性を保証対象としない．

3.2 保護対象とセキュリティ目標

保護対象は，秘密鍵，ポリシー，署名可否の判断結果，およびトランザクションから抽出した署名対象データである．本稿のセキュリティ目標は，未信頼領域の攻撃者による秘密鍵の取得を防ぎ，TEE 内で抽出した署名対象データをポリシーと照合して，事前承認された範囲に適合する要求だけに自動的に署名することである．ただし，本手法は要求が悪意に基づくかどうかを判定しないため，攻撃者が生成した要求であっても，ポリシーに適合すれば自動署名されうる．

© 2026 Information Processing Society of Japan

3.3 セキュリティ要件

以上の脅威モデルから，次の要件を定める．

R1 鍵の隔離
秘密鍵を TEE 内で保持し，未信頼領域へ出力しない．

R2 署名対象データの抽出
署名生成およびポリシー照合に用いる署名対象データを TEE 内で抽出する．

R3 判断の隔離
署名可否をクライアント PC や Normal World で判断せず，TEE 内で判断する．

R4 自動承認
ポリシーを満たす要求に限り，ユーザー確認なしで自動的に署名する．

R5 ポリシー保護
ポリシーを TEE 内で保持し，未信頼領域からの要求だけでは登録・変更を完了させない．

R6 抽出不能な要求の拒否
必須項目が欠落している要求，形式が不正な要求，または署名対象データを安全に抽出できない要求には署名しない．

署名対象データを抽出できるもののポリシーに適合しない要求は，自動署名せず，ユーザー確認へ移行する．

4. 提案手法

4.1 システム構成

図 1 に提案システムの構成を示す．システムは，未署名トランザクションを生成するクライアント PC，TEE を備えた署名装置，およびブロックチェーンネットワークからなる．署名装置の Normal World は通信とデータ中継を担う．TEE 内の TA は，秘密鍵とポリシーを保持し，入力検査，署名対象データの抽出，ポリシーとの照合，署名可否の判断，および署名生成を行う．クライアント PC と Normal World は署名可否を判断せず，TA が署名を許可した場合に限り，署名済みトランザクションを受け取る．

利用者は，自動署名を許可する範囲をポリシーとしてあらかじめ登録する．ポリシーの登録・変更は，その後の署名可否の判断に影響するため，通常の署名要求とは分けて扱う．

4.2 ポリシーによる事前承認

本稿では，署名要求を 1 件の登録済みポリシーと照合する．複数のポリシーが同時に該当する場合の優先順位付けや統合は，本稿では扱わない．本稿で用いるポリシーは，以下の項目で構成される．

- chainId：署名対象とするブロックチェーンの識別値
- to：ETH 送金先アドレス，または呼び出し先コントラクトアドレス
- value：ETH 送金額，またはコントラクト呼び出し時に付随する ETH 額
- gas：トランザクションで許可する gas 上限
- selector：呼び出しを許可する関数を表す識別子
- recipient：ERC20 transfer におけるトークン受取人
- amount：ERC20 transfer におけるトークン数量

chainId，to，selector，および recipient は許可リストとして保持し，value，amount，および gas には上限値を設定する．署名要求に複数の条件を適用する場合，署名装置はすべての条件を検査し，いずれか一つでも満たさなければ自動署名の対象から除外する．

単純な ETH 送金のポリシー照合には，許可する chainId と送金先アドレス，ならびに value と gas の上限を用いる．ERC20 transfer のポリシー照合には，許可する chainId，コントラクトアドレス，selector，recipient，ならびに amount と gas の上限を用いる．コントラクト呼び出しでは，to が示すアドレスは資産の受取人とは限らない．そこで，TA は calldata の先頭 4 バイトから selector を取得し，transfer の引数から recipient と amount を抽出してポリシーと照合する．

トランザクション Tx から署名対象データを安全に抽出でき，適用されるポリシーのすべての条件を満たす場合，ポリシー照合結果 $P(\mathrm{Tx})$ を真とする．必須項目が欠落している場合，値の形式が不正な場合，または署名対象データを安全に抽出できない場合は，$P(\mathrm{Tx})$ を評価せず，要求を拒否する．一方，署名対象データを安全に抽出できた要求は，ポリシーに適合しない場合でも抽出失敗とはみなさない．例えば，approve や transferFrom のように，形式は正しいが selector が許可リストに含まれない要求は，ポリシー不適合と判定して $P(\mathrm{Tx})$ を偽とし，自動署名せずユーザー確認の対象とする．selector，recipient，amount など，適用される条件のいずれかを満たさない場合も，同様に $P(\mathrm{Tx})$ を偽とする．

表 2: TEE 内の署名判断
Table 2 Signing decisions inside the TEE.

署名対象データの抽出	ポリシー	処理
成功	適合	自動署名
成功	不適合	ユーザー確認
失敗	評価しない	拒否

4.3 署名判断の分岐

TA は署名要求に対する処理を，表 2 に示す三つに分岐させる．

署名対象データの抽出に成功し，$P(\mathrm{Tx})$ が真であれば，TA は TEE 内の秘密鍵を用いて自動的に署名する．抽出に成功しても $P(\mathrm{Tx})$ が偽であれば，自動署名せずユーザー

© 2026 Information Processing Society of Japan

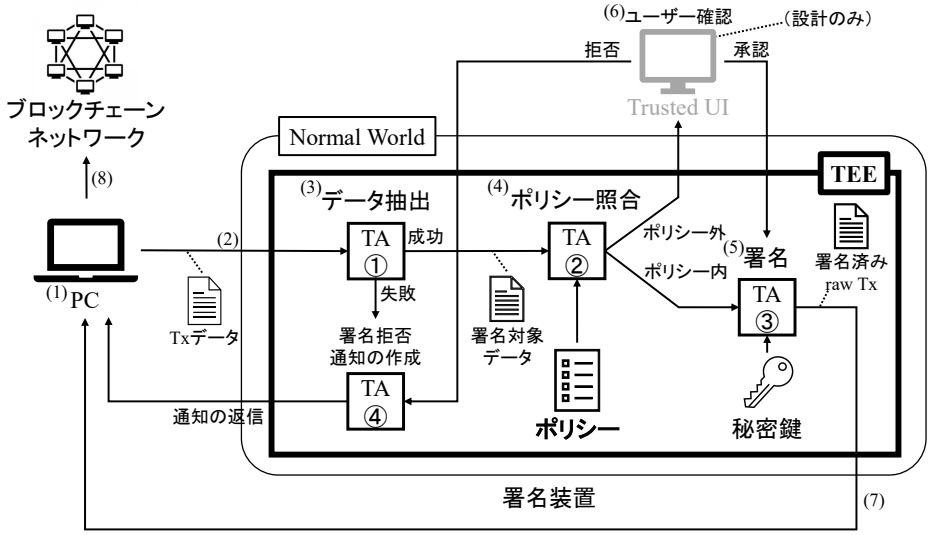


図 1: 提案システムの構成

Fig. 1 Architecture of the proposed system.

確認へ移行し，利用者が承認した場合に限り署名する．抽出に失敗した場合は，署名を拒否する．この分岐により，署名対象データを安全に抽出できない要求が，ユーザー確認を経て署名されることを防ぐ．

ポリシー登録・変更要求についても TA 内で必須項目と形式を検査する．形式検査を通過した要求については，登録内容または既存ポリシーとの差分をユーザー確認画面に表示し，利用者が承認した場合に限り，TEE 内のポリシーへ反映する．本実装では，ユーザー確認画面の表示・入力を Normal World で処理する．

4.4 署名要求の処理フロー

署名要求の処理を図 1 の番号 (1)–(8) に沿って示す．

(1) クライアント PC は未署名トランザクションを生成する．

(2) クライアント PC は署名装置の Normal World を介して TA へ署名要求を送る．

(3) TA は要求を未信頼入力として形式検査し，署名対象データを抽出する．

(4) TA は抽出したデータを TEE 内のポリシーと照合する．署名対象データを抽出できない場合は，ポリシー照合を行わず，要求を拒否する．

(5) ポリシー照合結果 $P(\mathrm{Tx})$ が真であれば，自動的に署名する．

(6) $P(\mathrm{Tx})$ が偽であれば，自動署名せず，ユーザー確認へ移行する．ユーザー確認へ移行した場合は，利用者が承認したときに限り署名を生成する．

(7) TA は，生成した署名済みトランザクションを Normal World を介してクライアント PC へ返す．

(8) クライアント PC は，受け取った署名済みトランザクションをブロックチェーンネットワークへ送信する．

クライアント PC と Normal World は署名要求と署名済みトランザクションを中継し，署名対象データの抽出，ポリシーとの照合，署名可否の判断，および秘密鍵を用いた署名生成は TEE 内で完結する．

5. 実装

5.1 実装環境

実装環境を表 3 に示す．クライアント PC と署名装置は USB で接続し，ネットワークを介さずに通信する．署名装置はブロックチェーンネットワークへ直接接続せず，署名済みトランザクションをクライアント PC へ返す．クライアント PC は，受け取った署名済みトランザクションを別ホスト上で稼働する GoQuorum 実験チェーンへ送信する．実資産を扱うネットワークは使用していない．

5.2 TA と host プログラム

本実装では，署名対象データの抽出，ポリシーとの照合，署名可否の判断，および署名生成を行う TA を OP-TEE 上に実装した．Normal World の host プログラムは，TEE Client API を用いて TA とのセッションを確立し，クライアント PC から受信した署名要求やポリシーの登録・変更要求を TA へ渡す．host プログラムは要求の中継と処理結果の返送のみを担い，署名可否の判断や秘密鍵の管理には関与しない．

TA は，署名に用いる secp256k1 秘密鍵を TEE 内の Secure Storage に保持する．本実装では，署名処理時に秘密鍵が未登録の場合，TA 内で秘密鍵と公開鍵を生成する．一方，実運用では利用者が管理する秘密鍵を TEE 内に登録

© 2026 Information Processing Society of Japan

表 3: 実装・評価環境
Table 3 Implementation and evaluation environment.

項目	構成
クライアント PC	Ubuntu 24.04.1
署名装置	Raspberry Pi 3 Model B+
TEE	OP-TEE 4.10.0
通信	USB–UART
実験チェーン	GoQuorum 24.4.1

し，その秘密鍵を用いて署名する構成を想定する．実運用における秘密鍵の安全な生成・登録方法は，本稿では扱わない．いずれの場合も，公開鍵の Keccak-256 ハッシュの下位 20 バイトから Ethereum アドレスを導出する．秘密鍵は Normal World にもクライアント PC にも出力しない．

5.3 署名対象データの抽出と署名生成

未署名トランザクションは JSON 形式で受け取る．TA は署名対象データとして chainId，nonce，to，value，gas，gasPrice，data を抽出する．このうち，chainId，to，value，gas，および data から抽出した selector，recipient，amount をポリシーとの照合に用いる．nonce と gasPrice は署名対象データに含めるが，本実装ではポリシーとの照合に用いない．ETH 送金では，to を送金先アドレス，value を送金額として扱う．ERC20 transfer では，to をコントラクトアドレスとして扱い，data から関数セレクタ，トークン受取人，およびトークン数量を抽出する．必須項目が欠落している要求，値の形式が不正な要求，または署名対象データを安全に抽出できない要求は拒否する．

署名が許可されると，TA は Ethereum legacy transaction の署名対象データを EIP-155 形式に従って RLP エンコードし，Keccak-256 ハッシュを計算する．TA は TEE 内の秘密鍵を用いて ECDSA 署名を生成し，v，r，s を含む署名済みトランザクションを組み立てて host プログラムへ返す．付録の図 A·1 に，署名要求の受信から署名対象データの抽出，ポリシーとの照合，ユーザー確認，署名済みトランザクションの返送までの実装フローを示す．

5.4 ポリシー管理とユーザー確認

利用者は署名要求の処理に先立ってポリシーを登録し，TA はこれを TEE 内の Secure Storage に保持する．ポリシーを登録または変更する場合，クライアント PC は対応する要求を作成し，Normal World の host プログラムを介して TA へ送る．host プログラムは要求を中継するだけであり，要求の検査，ポリシーの保存，および変更可否の判断は TA が行う．

TA はポリシー要求を未信頼入力として扱い，必須項目と値の形式を検査する．検査に失敗した場合，TA は要求を拒否し，登録済みポリシーを変更しない．検査に成功した場合，登録要求ではポリシー全体を，変更要求では登録済みポリシーと要求内容との差分を確認対象とする．利用者が内容を承認すると，TA は承認された内容に基づいてポリシーを登録または変更し，その後の署名可否の判断に用いる．

P(Tx) が偽のトランザクションについてユーザー確認を行っている間は，ポリシー変更を受け付けず，ユーザー確認時と署名時で判定条件が変化しないようにする．

6. 評価

6.1 評価目的と条件

表 3 の実装・評価環境を用い，GoQuorum 実験チェーン上で次の 6 点を評価した．

(1) TEE 内で生成した署名済みトランザクションが Ethereum 互換の GoQuorum 実験チェーンで受理されること

(2) P(Tx) が真の要求が自動署名されること

(3) P(Tx) が偽の要求が自動署名されず，ユーザー確認へ移行すること

(4) 署名対象データを安全に抽出できない要求が拒否されること

(5) ポリシー登録・変更要求が検査，確認，反映の順に処理されること

(6) 提案実装の各処理時間と，Normal World 上で自動署名する比較条件の処理時間

R1 は，Normal World 側から Secure Storage の保存データを読み出し，秘密鍵の平文が含まれるかを調べた．R3 は，署名可否を判断する処理の配置と host プログラムの処理範囲を，実装コード上で調査した．R2，R4，R6 は，署名要求に対する TA の処理結果に基づいて評価した．R5 は，ポリシー登録・変更要求に対する形式検査と，承認入力後の反映処理を評価対象とした．処理時間は各項目を 10 回測定して平均値を求め，ポリシー外要求およびポリシー変更要求のユーザー操作待ち時間は除いた．

6.2 署名判断とポリシー管理の機能確認

表 4 に，対応要件，入力条件・変更項目，および確認結果を示す．R1 の評価では，Normal World 側から読み出した Secure Storage の保存データは暗号化されたバイナリデータであり，秘密鍵の平文は観測されなかった．R3 の評価では，署名可否の判断が TA 内で行われ，host プログラムが要求と処理結果の中継のみを担うことを実装コード上で確認した．P(Tx) が真の ETH 送金と ERC20 transfer に対しては，TA が自動的に署名し，いずれも署名済みトランザクションを返した．

P(Tx) が偽となる要求は，ETH 送金では送金先，value，

© 2026 Information Processing Society of Japan

表 4: 署名判断とポリシー管理の機能確認結果
Table 4 Functional results of signing decisions and policy management.

対応要件	入力条件・変更項目	確認結果
R1	Normal World 側からの Secure Storage 保存データの読み出し	暗号化されたバイナリデータのみを取得し，秘密鍵の平文は確認されなかった
R2–R4	許可された ETH 送金および ERC20 transfer	自動署名し，署名済みデータを返した
R2–R4	ETH 送金の送金先，value, chainId, または gas 上限を許可範囲外へ変更	自動署名せず，ユーザー確認要求を返した
R2–R4	ERC20 transfer のコントラクト，selector，recipient，または amount を許可範囲外へ変更	自動署名せず，ユーザー確認要求を返した
R2，R6	必須項目の欠落，値の形式不正，または署名対象データを安全に抽出できない要求	拒否し，署名済みデータを生成しなかった
R5	形式不正なポリシー登録・変更要求	要求を拒否した
R5	形式検査に成功したポリシー登録・変更要求	確認要求を返し，承認後に反映した

chainId，gas 上限のいずれかを，ERC20 transfer ではコントラクト，selector，recipient，amount のいずれかを許可範囲外に変更して作成した．いずれの要求も自動署名されず，ユーザー確認要求が返された．必須項目が欠落した要求，値の形式が不正な要求，署名対象データを安全に抽出できない要求はいずれも拒否され，署名済みトランザクションは生成されなかった．

ポリシーの登録・変更要求では，形式が不正な要求を拒否した．形式検査を通過した要求はユーザー確認へ移行し，承認入力後に TA 内のポリシーへ反映された．攻撃者がクライアント PC または Normal World を制御する状況を想定し，Secure Storage の保存データの読み出し，署名要求の許可範囲外への改ざん，抽出不能な署名要求の送信，および形式が不正なポリシー登録・変更要求の送信を試行した．その結果，秘密鍵の平文は確認されず，ポリシーに適合しない要求は自動署名されずにユーザー確認へ移行し，抽出不能な署名要求と形式が不正なポリシー登録・変更要求は拒否された．

6.3 受理確認と処理時間

6.3.1 署名済みトランザクションの受理

TA が生成した署名済みトランザクションを，クライアント PC から GoQuorum 実験チェーンへ送信した．その結果，トランザクションが受理され，指定した宛先への送金が記録された．この結果から，TEE 内で生成した署名済みトランザクションが GoQuorum 実験チェーンで有効に処理されることを確認した．

表 5: 処理時間（各 10 回の平均，操作待ちを除く）
Table 5 Processing time (mean of ten runs, excluding human wait).

測定項目	最小	最大	平均
P(Tx) が真の要求の署名処理	667 ms	677 ms	670 ms
P(Tx) が偽の要求の署名処理	665 ms	667 ms	666 ms
TEE 内の署名生成	14 ms	15 ms	14 ms
ポリシー変更処理	225 ms	294 ms	245 ms

表 6: TEE の有無による処理時間の比較（各 10 回の平均）
Table 6 Comparison of processing time with and without TEE (mean of ten runs).

測定項目	最小	最大	平均
P(Tx) が真の要求の署名処理	667 ms	677 ms	670 ms
Normal World 上の自動署名	368 ms	379 ms	371 ms

6.3.2 処理時間

chainId，nonce，to，value，gas，gasPrice を含む単純な ETH 送金要求における署名処理時間を測定した．P(Tx) が偽の要求には，value がポリシーの上限値を超える ETH 送金要求を用いた．ポリシー変更処理の測定には，value の上限値を変更する要求を用いた．

各項目の測定結果を表 5 および表 6 に示す．各項目は，Python の time モジュールを用いて 10 回ずつ測定し，平均時間を算出した．P(Tx) が偽の要求およびポリシー変更要求のユーザー操作待ち時間は含めない．

P(Tx) が真の要求では，クライアント PC が要求を送信してから署名済みトランザクションを受信するまでを測定した．P(Tx) が偽の要求では，要求を送信してからユーザー確認要求を受信するまでを測定した．TEE 内の署名生成時間には，ハッシュ生成，secp256k1 署名，および署名済みトランザクションの組立てを含めた．ポリシー変更処理は，クライアント PC が要求を送信してから TA 内のポリシーに反映されるまでを測定した．比較条件では，提案実装と同じ Raspberry Pi の Normal World 上で，P(Tx) が真となるトランザクションに自動的に署名した．その際に用いた要求内容とポリシーは，TEE 内での測定に用いたものと同じである．Normal World 上の比較条件の平均処理時間は 371 ms，TEE 内で署名対象データの抽出，ポリシーとの照合，署名可否の判断，および署名生成を行う提案実装は 670 ms であった．いずれも本評価環境では 1 秒未満で処理を完了した．本比較では，提案実装の平均処理時間は Normal World 上の比較条件より 299 ms 長かった．

© 2026 Information Processing Society of Japan

また，P(Tx) が偽の要求の平均処理時間は 666 ms，TEE 内の署名生成は 14 ms，ポリシー変更処理は 245 ms であった．ただし，P(Tx) が真の場合は署名済みトランザクションを受信するまで，偽の場合はユーザー確認要求を受信するまでを測定しており，測定区間の終了点が異なる．このため，670 ms と 666 ms を単純に比較して，署名生成など個別処理の影響を評価することはできない．

7. 考察と限界

7.1 ポリシーで表せる意図の限界

提案手法は要求の悪意を判定しないため，攻撃者が生成した要求であっても，送金先や金額がポリシーに適合すれば自動署名されうる．本稿で用いるポリシーは，宛先，コントラクト，関数，受取人の許可リストと，金額，数量，gas の上限で構成され，単位時間当たりの回数，累積額，時刻，nonce の連続性，オンチェーン状態は条件として扱わない．そのため，同一内容の要求を繰り返し送信する再送攻撃は，要求がポリシーに適合する限り，本手法では抑止できない．自動署名を許可する範囲をより細かく制御するには，頻度，累積額，オンチェーン状態に基づく条件と，それらを安全に更新する仕組みが必要である．

7.2 確認経路と信頼仮定

P(Tx) が偽の署名要求やポリシーの登録・変更要求では，利用者が署名対象データまたは変更内容を信頼できる経路で確認する必要がある．本実装では，ユーザー確認の表示・入力が Normal World を介するため，確認経路の完全性を保証できない．今後は，TEE が入出力デバイスを直接制御する Trusted UI を実装する必要がある．

7.3 実装・評価上の限界

本稿の実装・評価は, Raspberry Pi 3B+, OP-TEE 4.10.0, Ethereum legacy transaction，ETH 送金と ERC20 transfer，および GoQuorum 実験チェーンを対象とした．今後は，他のトランザクション形式，任意のスマートコントラクト呼び出し，複数のポリシー，並行処理，および公開テストネットへ評価範囲を広げる．秘密鍵のバックアップと安全な登録経路，装置の紛失・故障時の復旧は，今後検討すべき運用上の課題である．

8. おわりに

本稿では，クライアント PC，通信路，および署名装置の Normal World を信頼しないことを前提とし，秘密鍵を TEE 内に保持するとともに，署名対象データの抽出，ポリシーとの照合，署名可否の判断，および署名生成を TEE 内で行う Web3 トランザクションの自動署名システムを提案した．利用者が自動署名を許可する範囲を，事前承認したポリシーとして表現した．署名対象データを安全に抽出できた要求は，ポリシーに適合すれば自動的に署名し，適合しなければユーザー確認へ移行する．署名対象データを安全に抽出できない要求は拒否する．

Raspberry Pi 3B+と OP-TEE による実装では，TEE 内で生成した署名済みトランザクションが GoQuorum 実験チェーンで受理され，三つの処理分岐が動作することを確認した．ポリシーに適合する要求の処理時間は，10 回の測定で平均 670 ms であった．

参考文献

[1] Houy, S., Schmid, P. and Bartel, A.: Security Aspects of Cryptocurrency Wallets—A Systematic Literature Review, *ACM Computing Surveys*, Vol.56, No.1 (2023).

[2] Erinle, Y., Kethepalli, Y., Feng, Y. and Xu, J.: SoK: Design, Vulnerabilities, and Security Measures of Cryptocurrency Wallets, *Computer Networks* (2025).

[3] Arapinis, M., Gkaniatsou, A., Karakostas, D. and Kiayias, A.: A Formal Treatment of Hardware Wallets, *Financial Cryptography and Data Security (FC 2019)*, LNCS, Vol.11598, Springer (2019).

[4] Ivanov, N. and Yan, Q.: EthClipper: A Clipboard Meddling Attack on Hardware Wallets with Address Verification Evasion, *Proc. IEEE Conference on Communications and Network Security (CNS)* (2021).

[5] Pinto, S. and Santos, N.: Demystifying Arm TrustZone: A Comprehensive Survey, *ACM Computing Surveys*, Vol.51, No.6 (2019).

[6] Gentilal, M., Martins, P. and Sousa, L.: TrustZone-backed Bitcoin Wallet, *Proc. 4th Workshop on Cryptography and Security in Computing Systems (CS2 '17)*, ACM (2017).

[7] Dai, W., Deng, J., Wang, Q., Cui, C., Zou, D. and Jin, H.: SBLWT: A Secure Blockchain Lightweight Wallet Based on TrustZone, *IEEE Access*, Vol.6 (2018).

[8] Athalye, A., Belay, A., Kaashoek, M. F., Morris, R. and Zeldovich, N.: Notary: A Device for Secure Transaction Approval, *Proc. 27th ACM Symposium on Operating Systems Principles (SOSP)* (2019).

[9] 小林紘也，面和成：不正なトランザクションの発行を防ぐコールドウォレットシステム，コンピュータセキュリティシンポジウム 2025 論文集，pp.1891–1898 (2025).

[10] Konoth, R. K., Fischer, B., Fokkink, W., Athanasopoulos, E., Razavi, K. and Bos, H.: SecurePay: Strengthening Two-Factor Authentication for Arbitrary Transactions, *Proc. IEEE European Symposium on Security and Privacy (EuroS&P)* (2020).

[11] Castillo, L. et al.: ERC-7730: Structured Data Clear Signing Format, Ethereum Improvement Proposals, No.7730 (2024).

[12] Buterin, V., Weiss, Y., Tirosh, D., Nacson, S., Forshtat, A., Gazso, K. and Hess, T.: ERC-4337: Account Abstraction Using Alt Mempool, Ethereum Improvement Proposals, No.4337 (2021).

[13] Pan, Z., Li, Y., Guan, Z., Hu, J. and Chen, Z.: OmniIntent: A Trusted Intent-Centric Framework for User-Friendly Web3, arXiv preprint arXiv:2603.04168 (2026).

© 2026 Information Processing Society of Japan

付　　録

A.1　実装したシステムのフロー図

図 A·1 は，実装したシステムにおけるポリシーの登録およびトランザクション署名の詳細な処理フローを示すシーケンス図である．ポリシーの登録では，クライアント PC から受信したポリシーを TEE 内で検査し，ユーザー確認を経て登録する．トランザクション署名では，TEE 内で署名対象データの抽出とポリシー照合を行い，ポリシーに適合する要求は自動署名し，不適合の要求はユーザー確認へ移す．署名済みトランザクションはクライアント PC へ返され，ブロックチェーンネットワークへ送信される．

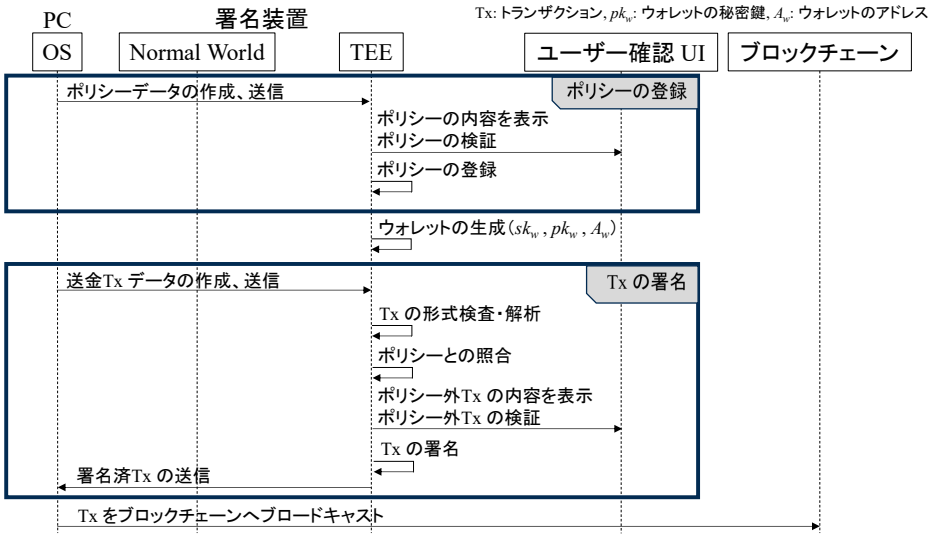


図 A·1: 実装したシステムの処理フロー図

Fig. A·1　Processing flow of the implemented system.

© 2026 Information Processing Society of Japan